QUESTION 9: BRUTE FORCE DETECTION

DG Interns Hub Cybersecurity Internship – Week 5 Submission

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** SIEM Analysis using Splunk (Event 4625 & SPL)

1. HOW BRUTE FORCE ATTACKS ARE DETECTED

Brute Force Detection relies on identifying high volumes of failed authentication events originating from a single source within a short timeframe. Security monitoring solutions like Splunk or Wazuh collect authentication logs from operating systems, applications, and network devices, correlating events using automated queries.

On Windows environments, failed authentication attempts generate **Event ID 4625** (*An account failed to log on*) in the Security log channel.

2. EXAMPLE SPLUNK SEARCH PROCESSING LANGUAGE (SPL) QUERY

```
index=* EventCode=4625 | stats count by src_ip | where count > 5
```

3. LINE-BY-LINE QUERY EXPLANATION

`index=*`: Searches across all indexed log data sources stored within Splunk (in operational SOC setups, specific indices like `index=win_logs` are used for faster performance). `EventCode=4625`: Filters the retrieved logs specifically for Windows Security Event ID 4625, isolating failed logon events. `| stats count by src_ip`: A pipe command that aggregates total event counts grouped by the source IP address (`src_ip`) initiating the logon requests. `| where count > 5`: Filters aggregated statistical results to display only source IP addresses that generated more than 5 failed logon attempts within the chosen search timeframe.

> **Field Extraction & Schema Variations**
>
> Field names depend on SIEM log parsing and Common Information Model (CIM) mappings. Native Windows logs may record `Source_Network_Address` or `Workstation_Name`, Sysmon logs may use `IpAddress`, and normalized Splunk environments map these to `src_ip` or `src`. Analysts should confirm field extractions in their active SIEM environment.

4. INTERPRETING RESULTS & SUSPICIOUS EXAMPLES

A typical detection table produced by this query highlights high-volume origin IPs:

src_ip	count	Observed Target Accounts	Triage Assessment
198.51.100.77	**342**	admin, root, administrator, user1	HIGH Active Password Spraying / External Brute Force
10.0.4.15	**8**	j_doe	LOW User typo / Expired saved password

5. POST-DETECTION ACTIONS FOR L1 ANALYSTS

Check for Successful Logons: Run a follow-up query for Event ID **4624** (Successful Logon) from the suspect source IP (198.51.100.77) to determine if the attack succeeded. **Enrich Threat Intel:** Query AbuseIPDB or VirusTotal with the source IP to check abuse confidence scores and past attack reports. **Determine Account Status:** Check Active Directory to verify if targeted accounts have been locked out due to domain password policies. **Initiate Containment / Escalation:** If a successful login is confirmed following brute force failures, immediately isolate the affected machine, disable compromised user credentials, and escalate ticket to Tier 2 IR. If all attempts failed, block the source IP at perimeter firewalls and close ticket.

6. TERMINOLOGY & REFERENCES

Event ID 4625: Windows Security log event triggered whenever a logon attempt fails. **Password Spraying:** Brute force variation where an attacker tries a few common passwords against many accounts to avoid lockout thresholds.

References:

• Splunk Search Processing Language (SPL) Documentation: **https://docs.splunk.com/**
• Microsoft Security Audit Event 4625 Reference: **https://learn.microsoft.com/**